

## **Zero Trust Network Segmentation & Enterprise Architecture**

### **Project Overview**

This capstone project demonstrates the design of a secure enterprise network architecture using Zero Trust principles for a healthcare organization with multiple departments, third-party vendors, remote users, and critical business systems.

The project addresses common security challenges found in large organizations, including excessive network trust, flat network design, lateral movement risks, unauthorized vendor access, and inadequate network visibility.

The solution introduces multi-layer network segmentation, secure remote access, firewall policy enforcement, identity verification, continuous monitoring, and compliance-oriented security controls.

---

### **Project Objective**

The primary objective of this project is to design a scalable and secure enterprise infrastructure that follows the Zero Trust security model.

### **Business Objectives**

- Protect critical healthcare systems and sensitive data.
- Secure third-party vendor access.
- Improve network visibility and monitoring.
- Reduce the attack surface.
- Support regulatory compliance requirements.
- Enable secure remote connectivity.

### **Security Objectives**

- Prevent lateral movement.
  - Enforce least privilege access.
  - Verify all users and devices before granting access.
  - Monitor and log security events.
  - Segment critical systems from general users.
- 

### **Business Scenario**

St. Mary's Regional Healthcare Network operates:

- Main Hospital
- Administrative Office
- Research Department
- Remote Clinics
- Third Party Vendors

The organization supports approximately 1,500 users and manages sensitive patient information, business records, and critical healthcare applications.

The existing flat network architecture presents significant security risks and requires redesign using Zero Trust principles.

---

## **Network Architecture Design**

The architecture is built around multiple security zones connected through firewalls and controlled network segmentation.

### **Core Components**

#### **Edge Security**

- Internet Connection
- Edge Firewall
- VPN Gateway

#### **Internal Infrastructure**

- Layer 3 Core Switch
- Internal Firewall Policies
- Segmented VLAN Architecture

#### **Security Controls**

- Multi Factor Authentication (MFA)
  - Active Directory
  - Role Based Access Control (RBAC)
  - IDS/IPS
  - SIEM
  - Endpoint Protection
-

## **VLAN Segmentation Strategy**

| <b>VLAN</b> | <b>Department</b> | <b>Subnet</b> |
|-------------|-------------------|---------------|
| VLAN 10     | Users             | 10.10.10.0/24 |
| VLAN 20     | Servers           | 10.10.20.0/24 |
| VLAN 30     | Clinical Systems  | 10.10.30.0/24 |
| VLAN 40     | Vendors           | 10.10.40.0/24 |
| VLAN 50     | Management        | 10.10.50.0/24 |
| VLAN 60     | Security Tools    | 10.10.60.0/24 |
| VLAN 70     | Staff Wireless    | 10.10.70.0/24 |
| VLAN 80     | Guest Wireless    | 10.10.80.0/24 |
| VLAN 90     | DMZ               | 10.10.90.0/24 |

---

## **Zero Trust Principles Implemented**

### **Verify Explicitly**

Every user and device must be authenticated and validated before access is granted.

Controls:

- Azure AD
- Active Directory
- MFA
- Conditional Access

---

### **Least Privilege Access**

Users receive only the permissions required to perform their job responsibilities.

Controls:

- RBAC
- Just-In-Time Access
- Vendor Access Restrictions

---

## **Assume Breach**

The network is designed assuming attackers may already be present.

Controls:

- VLAN Segmentation
- Internal Firewalls
- IDS/IPS
- SIEM Monitoring

---

## **Vendor Access Design**

Vendor access is restricted through a dedicated Vendor VLAN.

Access Process:

1. Vendor Authentication
2. MFA Verification
3. VPN Connection
4. Firewall Policy Inspection
5. Application Access

Restrictions:

- VPN only access
- Time-based access windows
- Session monitoring
- Application-specific permissions
- No access to domain controllers
- No access to internal databases

---

## **Firewall Policy Design**

The firewall enforces traffic inspection between all VLANs.

Examples:

**Allowed**

- Users → DNS Servers
- Clinical Systems → Database Servers
- Vendors → Application Servers

### **Denied**

- Users → Clinical Databases
- Vendors → Domain Controllers
- Internet → Internal Networks

Default policy:

Deny All

---

## **Security Monitoring Architecture**

### **SIEM**

Security Information and Event Management

Monitors:

- Authentication events
- Firewall logs
- Endpoint activity
- IDS/IPS alerts
- VPN activity

### **IDS/IPS**

Detects:

- Malware
  - Network scanning
  - Suspicious traffic
  - Unauthorized access attempts
- 

## **Risk Assessment**

| Risk             | Impact | Likelihood |
|------------------|--------|------------|
| Ransomware       | High   | High       |
| Vendor Breach    | High   | Medium     |
| Credential Theft | High   | High       |
| Data Leakage     | Medium | Medium     |
| Insider Threat   | Medium | Medium     |

---

### Compliance Alignment

The architecture aligns with:

- NIST SP 800-207 (Zero Trust Architecture)
- NIST Cybersecurity Framework
- HIPAA Security Principles
- PHIPA Security Principles

Key controls include:

- Access Control
  - Audit Logging
  - Encryption
  - Monitoring
  - Identity Verification
- 

### AWS Cloud Architecture

Cloud environment includes:

#### VPC

10.0.0.0/16

#### Public Subnet

- Bastion Host
- Internet Gateway

#### Private Subnet

- Application Server
- Database Server

### **Security Controls**

- Security Groups
  - IAM
  - CloudTrail
  - CloudWatch
  - Backup Policies
- 

### **Azure Zero Trust Architecture**

Components:

- Azure Active Directory
- Conditional Access
- MFA
- Microsoft Defender
- Enterprise Applications

Supported Applications:

- Office 365
  - Azure Portal
  - SaaS Applications
  - On-Premises Applications
- 

### **Technologies Used**

#### **Networking**

- Cisco Packet Tracer
- Cisco IOS
- VLANs
- Routing and Switching
- VPN Technologies

## **Security**

- Zero Trust Architecture
- IDS/IPS
- SIEM
- MFA
- RBAC
- Firewall Policy Design

## **Cloud**

- AWS VPC
- EC2
- RDS
- Azure AD
- Conditional Access

## **Systems Administration**

- Active Directory
- DNS
- DHCP
- Windows Server

---

## **Learning Outcomes**

This project demonstrates practical knowledge of:

- Enterprise Network Architecture
- Network Segmentation
- Zero Trust Design
- Firewall Policy Development
- Vendor Access Management
- Cloud Security Architecture
- Risk Assessment
- Compliance Mapping



- Security Monitoring

---

**Author**

**Shiva Subedi**

Computer Systems Technology

George Brown College